Security Exception Management System

Software Requirements Specification

IEEE 830-1998 outline

DRAFT — human review required

Version 1 | 2026-10-30T09:26:35.909048+00:00

Contents

1 Introduction 4
1.1 Purpose . . . 4
1.2 Scope . . . 4
1.3 Definitions, acronyms and abbreviations . . . 4
1.4 References . . . 4
1.5 Overview . . . 4
2 Overall description 5
2.1 Product perspective . . . 5
2.2 Product functions . . . 5
2.3 User characteristics and stakeholders . . . 5
2.4 Constraints . . . 6
2.5 Assumptions and dependencies . . . 6
3 Specific requirements 6
3.1 External interface requirements . . . 6
3.1.1 User interfaces . . . 6
3.1.2 Hardware interfaces . . . 6
3.1.3 Software interfaces . . . 6
3.1.4 Communications interfaces . . . 6
3.2 Functional requirements . . . 6
3.3 Performance requirements . . . 8
3.4 Logical database requirements . . . 8
3.5 Design constraints . . . 8
3.6 Software system attributes . . . 8
3.6.1 Reliability . . . 8
3.6.2 Availability . . . 8
3.6.3 Security . . . 8
3.6.4 Maintainability . . . 9
3.6.5 Portability . . . 9
3.7 Other requirements . . . 9
A Derived threat hypotheses 9
A.1 THR-001: User identities and authenticated access . . . 9
A.2 THR-002: Role and permission boundaries . . . 9
A.3 THR-003: Access grants and revocations . . . 10
A.4 THR-004: Administrative security decisions . . . 10
A.5 THR-005: Integration trust paths . . . 10
A.6 THR-006: Security and administrative audit evidence . . . 10
A.7 THR-007: Monitoring and security alerts . . . 11
B Risk assessment 11
B.1 RISK-001 . . . 11
B.2 RISK-002 . . . 11
B.3 RISK-003 . . . 12
B.4 RISK-004 . . . 12
B.5 RISK-005 . . . 12
B.6 RISK-006 . . . 13
B.7 RISK-007 . . . 13
C SDLC recommendation and delivery workflow 14
C.1 Ranking and source evidence . . . 14
C.1.1 Incremental suitability reasons . . . 15
C.1.2 Hybrid suitability reasons . . . 15

C.1.3 DevSecOps suitability reasons . . . 15
C.1.4 Spiral suitability reasons . . . 15
C.1.5 Agile suitability reasons . . . 15
C.1.6 V-Model suitability reasons . . . 15
C.1.7 Waterfall suitability reasons . . . 15
C.2 Methodology phases . . . 16
C.2.1 Requirements and verification planning . . . 16
C.2.2 Incremental delivery cycle . . . 17
C.2.3 Release and handoff . . . 19

1 Introduction

1.1 Purpose

This specification records the project purpose, stakeholder constraints and unresolved decisions stated in the source evidence below.

This SRS describes the software's required behavior for users, administrators and the Project Analyst reviewing the specification.

1.2 Scope

Design a secure university security exception management system that tracks requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services. Authorized security administrators should be able to review exception requests, record justification and supporting evidence, approve or reject requests, assign expiration dates, review active exceptions, and revoke exceptions when conditions change. The system should restrict access based on user roles, detect unauthorized changes to exception records, identify expired exceptions, generate security alerts, and maintain audit logs of exception decisions, record changes, and administrator actions. The platform should provide a centralized dashboard, integrate with existing university identity services, support multiple campus locations, and remain secure, reliable, scalable, and manageable.

1.3 Definitions, acronyms and abbreviations

Term	Meaning
Policy	A rule or decision governing permitted actions; its project-specific meaning remains defined by the source requirements.
Audit record	A stored record of an event. Required event scope and retention are determined by the linked source, not this definition.
Log	A collection of event records. This term does not itself require additional logging fields, events or access permissions.

1.4 References

Reference	Source
Format	IEEE Std 830-1998, clauses 5 and Annex A (document organization).

1.5 Overview

Section 2 summarizes the product, stakeholders and open decisions. Section 3 contains the uniquely identified requirements. Detailed evidence, acceptance procedures are available in the Normal report. Appendices A-C contain derived threat hypotheses, risk assessment and the proposed SDLC workflow.

2 Overall description

2.1 Product perspective

Design a secure university security exception management system that tracks requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services.

2.2 Product functions

Functional topics are summarized below; section 3 retains the full requirements.

- track requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services - FR-001
- allow Authorized security administrators to review exception requests - FR-002
- allow Authorized security administrators to record justification and supporting evidence - FR-003
- allow Authorized security administrators to approve or reject requests - FR-004
- allow Authorized security administrators to assign expiration dates - FR-005
- allow Authorized security administrators to review active exceptions - FR-006
- allow Authorized security administrators to revoke exceptions when conditions change - FR-007
- restrict access based on user roles - FR-008
- detect unauthorized changes to exception records - FR-009
- identify expired exceptions - FR-010
- generate security alerts - FR-011
- maintain audit logs of exception decisions - FR-012
- record changes, and administrator actions - FR-013
- provide a centralized dashboard - FR-014
- integrate with existing university identity services - FR-015
- support multiple campus locations - FR-016

2.3 User characteristics and stakeholders

Labels group stakeholders for readability. They do not combine permissions.

Education, training and experience requirements remain unspecified.

Role	Source user groups	Responsibility
User	user	Uses permitted functions; each source class keeps its specified permissions.
Admin	administrators	Performs only the role's source-defined operations in section 3.
Project Analyst	Document review role	Reviews requirements and tracks open decisions; this role grants no product access.

2.4 Constraints

No additional implementation constraints were confirmed. Source-defined restrictions remain in the requirements in section 3.

2.5 Assumptions and dependencies

Open decisions requiring confirmation:

- What conditions define the requested detections and their alert triggers?
- Which fields must the audit logs contain?
- What retention period is required for the audit logs?
- Which security acceptance outcomes must be demonstrated?
- What measurable reliability and recovery targets must the system meet?
- What measurable scalability targets must the system meet?
- What criteria define acceptable manageability?

3 Specific requirements

Each requirement is stated once with its original identifier and wording. Cross-references identify requirements covering more than one concern.

3.1 External interface requirements

3.1.1 User interfaces

Related requirements: FR-008, FR-014. Interface details beyond those requirements remain unspecified.

3.1.2 Hardware interfaces

No specific interface requirement was supplied; confirmation is required.

3.1.3 Software interfaces

Related requirements: FR-015. Interface details beyond those requirements remain unspecified.

3.1.4 Communications interfaces

No specific interface requirement was supplied; confirmation is required.

3.2 Functional requirements

FR-001 · Must · explicit

The system shall track requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services.

Traceability: E-001, TEST-001

FR-002 · Should · explicit

The system shall allow Authorized security administrators to review exception requests.

Traceability: E-002, TEST-002

FR-003 · Should · explicit

The system shall allow Authorized security administrators to record justification and supporting evidence.

Traceability: E-002, TEST-003

FR-004 · Should · explicit

The system shall allow Authorized security administrators to approve or reject requests.

Traceability: E-002, TEST-004

FR-005 · Should · explicit

The system shall allow Authorized security administrators to assign expiration dates.

Traceability: E-002, TEST-005

FR-006 · Should · explicit

The system shall allow Authorized security administrators to review active exceptions.

Traceability: E-002, TEST-006

FR-007 · Should · explicit

The system shall allow Authorized security administrators to revoke exceptions when conditions change.

Traceability: E-002, TEST-007

FR-008 · Should · explicit

The system shall restrict access based on user roles.

Traceability: E-003, TEST-008

FR-009 · Should · explicit

The system shall detect unauthorized changes to exception records.

Traceability: E-003, TEST-009

FR-010 · Should · explicit

The system shall identify expired exceptions.

Traceability: E-003, TEST-010

FR-011 · Should · explicit

The system shall generate security alerts.

Traceability: E-003, TEST-011

FR-012 · Should · explicit

The system shall maintain audit logs of exception decisions.

Traceability: E-003, TEST-012

FR-013 · Should · explicit

The system shall record changes, and administrator actions.

Traceability: E-003, TEST-013

FR-014 · Should · explicit

The system shall provide a centralized dashboard.

Traceability: E-004, TEST-014

FR-015 · Should · explicit

The system shall integrate with existing university identity services.

Traceability: E-004, TEST-015

FR-016 · Should · explicit

The system shall support multiple campus locations.

Traceability: E-004, TEST-016

3.3 Performance requirements

NFR-004 · Should · explicit

The system shall remain scalable.

Traceability: E-004, TEST-020

3.4 Logical database requirements

No separate requirement was specified in the supplied brief.

3.5 Design constraints

No separate requirement was specified in the supplied brief.

3.6 Software system attributes

3.6.1 Reliability

NFR-003 · Should · explicit

The system shall remain reliable.

Traceability: E-004, TEST-019

3.6.2 Availability

No separate requirement was specified in the supplied brief.

3.6.3 Security

Also covered by: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-011, FR-012.

NFR-001 · Must · explicit

The system shall be secure.

Traceability: E-001, TEST-017

NFR-002 · Should · explicit

The system shall remain secure.

Traceability: E-004, TEST-018

3.6.4 Maintainability

NFR-005 · Should · explicit

The system shall remain manageable.

Traceability: E-004, TEST-021

3.6.5 Portability

No separate requirement was specified in the supplied brief.

3.7 Other requirements

No separate requirement was specified in the supplied brief.

A Derived threat hypotheses

These are defensive planning hypotheses, not observed incidents or approved extra controls. Unrecognized threats and actual implementation effectiveness require human review.

These are planning hypotheses, not observed incidents or additional approved controls.

A.1 THR-001: User identities and authenticated access

Scenario: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Unauthorized use of a legitimate identity could expose resources or alter system state.

Linked requirements: FR-014, FR-015, FR-016, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.2 THR-002: Role and permission boundaries

Scenario: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the source-defined authorization boundary.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: A lower-privilege user could access restricted functions or sensitive resources.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-002, E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.3 THR-003: Access grants and revocations

Scenario: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: A formerly authorized principal could continue using access that is no longer approved.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007

Original evidence: E-002

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.4 THR-004: Administrative security decisions

Scenario: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Misused administrative authority could undermine protection or interrupt legitimate use.

Linked requirements: FR-001, NFR-001

Original evidence: E-001

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.5 THR-005: Integration trust paths

Scenario: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Untrusted integration data could cause incorrect decisions or hide security events.

Linked requirements: FR-014, FR-015, FR-016, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.6 THR-006: Security and administrative audit evidence

Scenario: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Investigators could lose reliable evidence of the events required by the brief.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-002, E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.7 THR-007: Monitoring and security alerts

Scenario: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Relevant suspicious activity could remain undetected or receive delayed investigation.

Linked requirements: FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

B Risk assessment

Risk treatments are proposals for review. Unknown likelihood and impact ratings mean unassessed; no numeric confidence or severity is inferred.

B.1 RISK-001

Derived risk affecting User identities and authenticated access: Unauthorized use of a legitimate identity could expose resources or alter system state.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Proposed treatment: Review impersonation and compromised-identity paths against the stated access duties; confirm any additional identity or session protections with the stakeholder. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-014, FR-015, FR-016, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

B.2 RISK-002

Derived risk affecting Role and permission boundaries: A lower-privilege user could access restricted functions or sensitive resources.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the

source-defined authorization boundary.

Proposed treatment: Test permitted and denied role/resource pairs against the linked authorization duties; review ambiguous permission assignments with the resource owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-002, E-003

B.3 RISK-003

Derived risk affecting Access grants and revocations: A formerly authorized principal could continue using access that is no longer approved.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Proposed treatment: Trace permission changes through subsequent access decisions and any active access; confirm revocation timing and session semantics before baselining them. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007

Original evidence: E-002

B.4 RISK-004

Derived risk affecting Administrative security decisions: Misused administrative authority could undermine protection or interrupt legitimate use.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Proposed treatment: Review misuse cases for each source-permitted administrative operation and compare its outcomes and audit coverage with the stated management boundary. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-001, NFR-001

Original evidence: E-001

B.5 RISK-005

Derived risk affecting Integration trust paths: Untrusted integration data could cause incorrect decisions or hide security events.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Proposed treatment: Review trust assumptions at the specified integration boundaries with missing or altered input fixtures; confirm the required failure handling with the owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-014, FR-015, FR-016, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

B.6 RISK-006

Derived risk affecting Security and administrative audit evidence: Investigators could lose reliable evidence of the events required by the brief.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Proposed treatment: Compare source-required events with the resulting audit evidence; assess missing and altered-record cases and confirm unprovided protection or retention decisions. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-002, E-003

B.7 RISK-007

Derived risk affecting Monitoring and security alerts: Relevant suspicious activity could remain undetected or receive delayed investigation.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Proposed treatment: Evaluate the stated detection duties with representative positive and negative events; confirm undecided thresholds, alert priorities and investigation responsibilities. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-008, FR-009, FR-010, FR-011, FR-012, FR-013

Original evidence: E-003

C SDLC recommendation and delivery workflow

Proposed lifecycle: Incremental

Security decisions benefit from security review and tests throughout delivery (E-002); monitoring and alert behavior needs validation with operational feedback (E-003); multiple deployment locations offer a staged validation and rollout opportunity (E-004); connected systems need integration verification before broader rollout (E-004). These derived factors support an Incremental lifecycle over Hybrid, DevSecOps, Spiral, Agile, V-Model, or Waterfall because continuous security assurance, operational feedback loops, staged deployment, and integration validation are best served by iterative delivery with controlled increments. The decision remains proposed due to unknown budget, delivery frequency, failure consequences, legacy system uncertainty, and regulation exposure.

Recommendation requires human confirmation of delivery constraints and team capacity. Suitability points are deterministic rule scores, not probabilities.

Policy version: sequential-sdlc-2.0

Unconfirmed decision factors: budget, delivery, failure consequences, feedback, legacy, regulation, schedule, stability, uncertainty, verification

- Recurring delivery requires stakeholder review and backlog refinement; a cycle does not guarantee completeness or remove unresolved decisions.
- Proposed suitability recommendation; confirm delivery constraints and team capacity before adopting this lifecycle. Missing factors are not assumed.

C.1 Ranking and source evidence

- security_assurance = integrated security review (derived). Security decisions benefit from security review and tests throughout delivery. Original evidence: E-002.
- operational_validation = monitoring feedback (derived). Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. Original evidence: E-003.
- deployment_scope = staged rollout opportunity (derived). Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. Original evidence: E-004.
- integration_assurance = integration validation (derived). Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. Original evidence: E-004.

Candidate	Suitability points
Incremental	66
Hybrid	65
DevSecOps	63
Spiral	51
Agile	40
V-Model	40
Waterfall	40

C.1.1 Incremental suitability reasons

- Derived operational_validation (+6 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+12 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)
- Derived integration_assurance (+8 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.2 Hybrid suitability reasons

- Derived security_assurance (+8 points): Security decisions benefit from security review and tests throughout delivery. (E-002)
- Derived operational_validation (+5 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+8 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)
- Derived integration_assurance (+4 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.3 DevSecOps suitability reasons

- Derived security_assurance (+12 points): Security decisions benefit from security review and tests throughout delivery. (E-002)
- Derived operational_validation (+8 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+3 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)

C.1.4 Spiral suitability reasons

- Derived security_assurance (+5 points): Security decisions benefit from security review and tests throughout delivery. (E-002)
- Derived integration_assurance (+6 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.5 Agile suitability reasons

- No differentiating input evidence

C.1.6 V-Model suitability reasons

- No differentiating input evidence

C.1.7 Waterfall suitability reasons

- No differentiating input evidence

C.2 Methodology phases

Activities reference the canonical requirements and proposed verification work. Human gates are pending decisions, not approval records.

C.2.1 Requirements and verification planning

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, FR-015, FR-016, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review and baseline the source-defined work group: FR-001: The system shall track requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services.; FR-002: The system shall allow Authorized security administrators to review exception requests.; FR-003: The system shall allow Authorized security administrators to record justification and supporting evidence.; FR-004: The system shall allow Authorized security administrators to approve or reject requests.; FR-005: The system shall allow Authorized security administrators to assign expiration dates.; FR-006: The system shall allow Authorized security administrators to review active exceptions.; FR-007: The system shall allow Authorized security administrators to revoke exceptions when conditions change.; FR-008: The system shall restrict access based on user roles.; FR-009: The system shall detect unauthorized changes to exception records.; FR-010: The system shall identify expired exceptions.; FR-011: The system shall generate security alerts.; FR-012: The system shall maintain audit logs of exception decisions.; FR-013: The system shall record changes, and administrator actions.; FR-014: The system shall provide a centralized dashboard.; FR-015: The system shall integrate with existing university identity services.; FR-016: The system shall support multiple campus locations.
- Activity: Review and baseline the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
- Activity: Create the unit, integration, system and acceptance test plan before implementation; retain each authored acceptance criterion.
- Deliverable: Versioned requirements baseline
- Deliverable: Unit, integration, system and acceptance test plan
- Deliverable: Unresolved-decision record
- Entry criterion: Authoritative inputs and canonical requirements are available for review.
- Exit criterion: A human reviewer has recorded the baseline decision and disposition of unresolved scope.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall restrict access based on user roles.
- Security check: Review implementation and acceptance evidence against FR-011: The system shall generate security alerts.
- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

C.2.2 Incremental delivery cycle

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, FR-015, FR-016, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review and prioritize the backlog for the next iteration without changing source-defined scope.
- Activity: Implement the source-defined work group: FR-001: The system shall track requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and IT services.; FR-002: The system shall allow Authorized security administrators to review exception requests.; FR-003: The system shall allow Authorized security administrators to record justification and supporting evidence.; FR-004: The system shall allow Authorized security administrators to approve or reject requests.; FR-005: The system shall allow Authorized security administrators to assign expiration dates.; FR-006: The system shall allow Authorized security administrators to review active exceptions.; FR-007: The system shall allow Authorized security administrators to revoke exceptions when conditions change.; FR-008: The system shall restrict access based on user roles.; FR-009: The system shall detect unauthorized changes to exception records.; FR-010: The system shall identify expired exceptions.; FR-011: The system shall generate security alerts.; FR-012: The system shall maintain audit logs of exception decisions.; FR-013: The system shall record changes, and administrator actions.; FR-014: The system shall provide a centralized dashboard.; FR-015: The system shall integrate with existing university identity services.; FR-016: The system shall support multiple campus locations.
- Activity: Implement the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
- Activity: In an authorized isolated test environment, execute TEST-001: Given: the system tracks requests for temporary exceptions to approved security policies across academic departments, administrative units, research environments, and When: an actor initiates a request for a temporary exception to an approved security policy Expected: the requested item is returned with its history available for examination
- Activity: In an authorized isolated test environment, execute TEST-002: Given: Authorized security administrators review exception requests When: initiate the review of named exception requests Expected: the requested exception request is returned for examination
- Activity: In an authorized isolated test environment, execute TEST-003: Given: Authorized security administrators perform a justification and supporting evidence recording When: execute the record justification and supporting evidence operation Expected: a recorded justification and supporting evidence is available for inspection
- Activity: In an authorized isolated test environment, execute TEST-004: Given: Authorized security administrators approve or reject a request When: approve a named exception request as the stated actor Expected: Authorized security administrators approved the named exception request
- Activity: In an authorized isolated test environment, execute TEST-005: Given: Authorized security administrators assign expiration dates When: initiate the assignment of an expiration date to a permission Expected: the assigned expiration date is reflected in the access state
- Activity: In an authorized isolated test environment, execute TEST-006: Given: Authorized security administrators review active exceptions When: request the list of active exception requests Expected: the list of active exception requests is returned for examination

- Activity: In an authorized isolated test environment, execute TEST-007: Given: Authorized security administrators revoke exceptions when conditions change When: initiate the revocation of an exception due to changed conditions Expected: the exception access is removed from the active state and no longer accessible
- Activity: In an authorized isolated test environment, execute TEST-008: Given: the system is configured with user roles and access policies When: a user attempts to access a resource beyond their assigned role Expected: access is denied and the system enforces the role-based restriction
- Activity: In an authorized isolated test environment, execute TEST-009: Given: an exception record is modified outside authorized procedures When: the system monitors for unauthorized changes to exception records Expected: the condition is identified and logged as a detected anomaly
- Activity: In an authorized isolated test environment, execute TEST-010: Given: an exception record has been set with an expiration date in the past When: the system evaluates the validity of exception records Expected: the expired exception is identified and marked as invalid
- Activity: In an authorized isolated test environment, execute TEST-011: Given: a security violation condition is triggered in the system When: the system detects a breach of exception policy Expected: a security alert exists and is generated as requested
- Activity: In an authorized isolated test environment, execute TEST-012: Given: an exception decision is made by an authorized user When: the system processes and records the decision Expected: a complete audit log entry exists for that decision
- Activity: In an authorized isolated test environment, execute TEST-013: Given: an administrator performs a configuration change or modifies an exception record When: the system records the action during operation Expected: a detailed record of the action is available for inspection
- Activity: In an authorized isolated test environment, execute TEST-014: Given: a system user opens the dashboard named in the source obligation When: the system loads and displays the dashboard Expected: the dashboard is visible and available for use
- Activity: In an authorized isolated test environment, execute TEST-015: Given: a system user initiates an authenticated exchange with the university identity service via the source-named integration point When: the system performs the interoperation as defined in the source obligation Expected: the exchange completes successfully and the system responds with a valid session token or status indication
- Activity: In an authorized isolated test environment, execute TEST-016: Given: a user initiates use from each of the three campus locations specified in the source obligation When: the system processes the request and attempts to serve it Expected: use succeeds at all three locations without error or redirection
- Activity: In an authorized isolated test environment, execute TEST-017: Given: A draft acceptance plan for this quality goal: the system shall be secure against unauthorized access and data exfiltration via network traffic. When: An analyst inspects or reviews that acceptance plan to determine whether measurable targets are defined or remain TBD. Expected: The plan's measurable targets remain TBD or unconfirmed, as no specific metrics, thresholds, or test cases are provided in the current draft.
- Activity: In an authorized isolated test environment, execute TEST-018: Given: The system shall remain secure under all operational and failure conditions. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: In an authorized isolated test environment, execute TEST-019: Given: The system shall remain reliable under all operational and failure conditions. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: In an authorized isolated test environment, execute TEST-020: Given: The system shall remain scalable under all operational and failure conditions. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.

- Activity: In an authorized isolated test environment, execute TEST-021: Given: The system shall remain manageable under all operational and failure conditions. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: Collect stakeholder feedback; agree its cadence with a human reviewer before scheduling cycles.
- Activity: Return accepted stakeholder feedback and observed defects to the backlog and plan the next iteration.
- Deliverable: Requirement-linked implementation increment
- Deliverable: Recorded test evidence
- Deliverable: Reviewed feedback and next-iteration backlog
- Entry criterion: Prior work, source scope and the reviewed test plan are available for iteration planning.
- Exit criterion: A human reviewer has assessed the increment, test evidence and feedback; unresolved changes return to the next iteration.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall restrict access based on user roles.
- Security check: Review implementation and acceptance evidence against FR-011: The system shall generate security alerts.
- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

C.2.3 Release and handoff

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, FR-015, FR-016, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review the exact requirements baseline, implementation links and verification evidence before a release decision.
- Activity: Carry unresolved source decisions into handoff; generated text is not human approval.
- Deliverable: Requirements and verification evidence package
- Deliverable: Pending human release decision
- Deliverable: Outstanding-decision record
- Entry criterion: Verification evidence and unresolved decisions are available for human review.
- Exit criterion: A human has recorded the release/handoff decision for the reviewed content.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall restrict access based on user roles.
- Security check: Review implementation and acceptance evidence against FR-011: The system shall generate security alerts.

- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

Detailed acceptance criteria, evidence, architecture and the SDLC plan are available in the supporting report and canonical JSON.

Canonical content SHA-256: 4dda481eda93da9fa5b0f634bc12dab0724db7f71addb5dd100dd8eb5ab421ac